Lab di threat intelligence: analisi del report CISA AA22-083A

Autore: Simone Calogero Lauria · Data: 9 novembre 2026

1. Riassunto della campagna

Il report in questione è un avviso congiunto di CISA, FBI e Dipartimento dell'Energia USA (AA22-083A) del 24 marzo 2022, relativo ad attacchi al settore energetico. L'attore è l'FSB (servizio di sicurezza russo). Il report cita anche un secondo soggetto, il TsNIIKhM, un istituto di ricerca russo, coinvolto nell'attacco TRITON del 2017, che manomise il sistema di sicurezza di una raffineria in Medio Oriente.

Le vittime, come indicato all'inizio dell'avviso, sono le compagnie del settore energetico e i loro fornitori. La campagna è durata dal 2011 al 2018 e si è svolta in due fasi. Nella prima (2013-2014), con il malware Havex, l'attore è entrato nelle reti e nei server tramite email di spearphishing, siti compromessi e aggiornamenti software manomessi, raccogliendo informazioni. Nella seconda (2016-2018) ha colpito prima fornitori e partner, poi le aziende energetiche vere e proprie. La campagna era volta al furto di documenti sugli schemi dei sistemi ICS.

È rilevante per un'azienda come Eni perché in alcuni casi mancavano misure di base, come l'MFA, relative al perimetro della rete (inteso non più come perimetro locale, ma come rete di persone e identità). Inoltre il rischio può arrivare da fornitori e partner: è quindi importante che l'intera rete, intesa come insieme di aziende, partner e fornitori, sia adeguatamente protetta.

Si precisa infine che questo è un report del 2022 su fatti avvenuti tra il 2011 e il 2018: vale quindi come riferimento sulle tecniche, non come elenco di minacce attuali.

2. Artefatti osservabili

Il report non contiene indicatori di rete (indirizzi IP, domini, hash dei file): è un documento centrato sulle TTP. Contiene però artefatti osservabili sugli host e sulla rete, riportati qui con la pagina del report.

Artefatto	Tipo	Pag.	Cosa faceva l'attaccante	Controllo indicato dal report
`dc.bat`, `dit.bat`	Script batch	26	Eseguiti su un domain controller, con credenziali privilegiate, per elencare host, utenti e altre informazioni sull'ambiente	Monitorare processi e argomenti da riga di comando; attenzione a ping.exe e tracert.exe lanciati in rapida successione
`dirsb.bat`	Script batch	27	Raccoglieva i nomi di cartelle e file dagli host	Monitorare i comandi di raccolta

Artefatto	Tipo	Pag.	Cosa faceva l'attaccante	Controllo indicato dal report
			della rete	informazioni: tecnica difficile da bloccare in via preventiva
`scr.exe`	Eseguibile (utility per screenshot)	21, 30-31	Lanciato con attività pianificate e script per catturare lo schermo dei sistemi in rete, anche quelli con dati sui sistemi di controllo; a fine operazione veniva cancellato insieme agli script e ai file prodotti	Segmentazione di rete, MFA, rimozione dei programmi non necessari; monitoraggio delle cancellazioni da riga di comando
`pss.bat`, `psc.bat`	Script batch	31	Avviavano PsExec per eseguire scr.exe sui sistemi della rete e salvare gli screenshot in un file di testo	Limitare gli accessi di rete e il software installabile; segmentazione
`ntds.dit`	File (database di Active Directory con le password cifrate degli utenti del dominio)	25, 30	L'attaccante ha copiato il file dai server	Monitorare processi e comandi che tentano di accedere o copiare ntds.dit
`SYSTEM.zip`, `comps.zip`	Archivi compressi	30	Contenevano ntds.dit e il registry hive SYSTEM, compressi per portarli fuori dalla rete	Audit di sistemi e permessi per individuare configurazioni deboli
File `LNK` con icona remota	File di collegamento modificato	23	L'icona puntava a un server controllato dagli attaccanti: quando l'utente apriva la cartella, Windows avviava una connessione SMB inviando le credenziali	Politiche password robuste; filtrare il traffico di rete, anche in uscita
Documenti Word	Allegati email	22	Una funzione legittima di Word recuperava un	Politiche password; filtro

Artefatto	Tipo	Pag.	Cosa faceva l'attaccante	Controllo indicato dal report
di spearphishing			documento da un server remoto via SMB, inviando l'hash delle credenziali dell'utente anche se il file non veniva scaricato	del traffico SMB in uscita
Hydra, SecretsDump, CrackMapExec e Python	Strumenti open source	22	Usati per violare le password dagli hash di credenziali ottenuti	MFA e politiche password
PsExec	Strumento di amministrazione remota	28, 31	Usato per muoversi tra i sistemi (insieme a RDP, VNC e condivisioni admin) ed eseguire programmi da remoto	Segmentazione, MFA, gestione degli account privilegiati
Script JavaScript con Command Shell	Script	17-18	Creava un amministratore locale, disattivava il firewall dell'host, apriva la porta 3389 e aggiungeva l'account al gruppo degli amministratori	Bloccare l'esecuzione di codice non autorizzato (application control e blocco degli script)
Attività pianificata	Scheduled Task	18	Disconnetteva automaticamente un account appena creato ogni otto ore	Audit e gestione degli account privilegiati
TCP 445 e 139	Porte SMB	22	Usate per far inviare le credenziali a un server esterno (documenti Word, siti compromessi, file LNK)	Filtrare il traffico in uscita
TCP 3389	Porta RDP	15, 17, 28	Aperta dall'attaccante sui sistemi compromessi e usata per l'accesso remoto e il movimento laterale	MFA su accessi remoti, gateway RDP, limitare l'accesso
UDP 1502	Porta del protocollo	34-35	Usata dal malware TRITON per comunicare	IDS con allarmi su traffico ICS fuori

Artefatto	Tipo	Pag.	Cosa faceva l'attaccante	Controllo indicato dal report
	TriStation (TRITON)		con i PLC Triconex e individuarli in rete	dalla norma (pag. 6)

Nota: perché un artefatto da solo non è una prova

Strumenti come PsExec, Hydra e gli script batch sono usati anche da amministratori di sistema e da tester autorizzati, e i nomi dei file possono essere cambiati con facilità (il report descrive anche attaccanti che rinominano le estensioni). Per questo un nome di file va usato come indizio da correlare con altri elementi (orario, utente, rete di provenienza, sequenza delle azioni), non come prova a sé. Vale lo stesso per le porte: 445 e 3389 sono normali all'interno della rete, mentre sono sospette soprattutto verso l'esterno.

3. Mappatura MITRE ATT&CK della campagna 2016-2018

La campagna 2016-2018 usa tecniche in 11 tattiche ATT&CK, dal furto di credenziali fino alla raccolta di dati sui sistemi ICS, in gran parte con strumenti comuni. I codici sono quelli indicati nel report (ATT&CK for Enterprise v10); le pagine sono quelle dell'avviso AA22-083A.

Tattica	ID	Tecnica	Cosa è successo	Pag.
Reconnaissance (TA0043)	T1589.001	Raccolta di credenziali delle vittime	Email di spearphishing con allegati e link abbreviati che portavano a pagine che chiedevano indirizzo email e password; stessa attività classificata anche come phishing per informazioni (T1598.002, T1598.003)	13-14
Resource Development (TA0042)	T1584.004	Compromissione di server di terzi	Creati watering hole (siti di terzi compromessi, usati come trappola)	14
Initial Access (TA0001)	T1078	Account validi	Credenziali già rubate usate su VPN, RDP e Outlook Web Access dove l'MFA non era attivo	15
Initial Access (TA0001)	T1133	Servizi remoti esterni	Installati client VPN su sistemi di terzi compromessi per collegarsi alle reti energetiche	16
Execution (TA0002)	T1059.001	PowerShell	Durante una sessione RDP, uno script PowerShell ha creato un account su un server Exchange	17

Tattica	ID	Tecnica	Cosa è successo	Pag.
Execution (TA0002)	T1059.003	Windows Command Shell	Uno script JavaScript con shell creava un amministratore locale, disattivava il firewall dell'host, apriva la porta 3389 e aggiungeva l'account agli amministratori	17-18
Execution (TA0002)	T1053.005	Attività pianificata	Un task disconnetteva ogni otto ore l'account appena creato	18
Persistence (TA0003)	T1136.001	Creazione di account locale	Creati amministratori locali su organizzazioni terze compromesse, per accedere poi alle aziende energetiche	19
Persistence (TA0003)	T1505.003	Web shell	Installate su server web e di posta esposti su Internet	19
Defense Evasion (TA0005)	T1070.001	Cancellazione dei log di Windows	Cancellati i log System, Security, Terminal Services, Remote Services e Audit; rimossi anche il client VPN installato e i suoi log	20
Defense Evasion (TA0005)	T1070.004	Cancellazione di file	Eliminati screenshot, chiavi di registro, script batch, file di output e strumenti come scr.exe	21
Defense Evasion (TA0005)	T1036	Mascheramento	Rinominate le estensioni degli strumenti scaricati	21
Credential Access (TA0006)	T1110.002	Password cracking	Hydra, SecretsDump, CrackMapExec e Python usati per ricavare le password dagli hash ottenuti	22
Credential Access (TA0006)	T1187	Autenticazione forzata	Documenti Word, siti compromessi e file LNK costringevano il computer a collegarsi via SMB a server degli attaccanti, che ricevevano l'hash delle credenziali	22-23
Credential Access (TA0006)	T1003.001	Memoria di LSASS	Con PowerShell da amministratore hanno abilitato WDigest, così le password	24

Tattica	ID	Tecnica	Cosa è successo	Pag.
			restavano in chiaro in memoria e potevano essere estratte	
Credential Access (TA0006)	T1003.003	Database NTDS	Copiato il file ntds.dit di Active Directory	25
Discovery (TA0007)	T1018	Scoperta di sistemi remoti	Su un domain controller, con credenziali privilegiate, gli script dc.bat e dit.bat elencavano host e utenti; poi accesso a postazioni e server con dati dei sistemi di controllo degli impianti	26-27
Discovery (TA0007)	T1083	Scoperta di file e directory	Script dirsb.bat per raccogliere nomi di cartelle e file; ricerca mirata dei file server	27
Lateral Movement (TA0008)	T1570	Trasferimento laterale di strumenti	Movimento con PsExec, script batch, RDP (T1021.001), condivisioni admin SMB (T1021.002) e VNC (T1021.005)	28
Collection (TA0009)	T1005	Dati dal sistema locale	Raccolto il file SYSTEM del registro di Windows	30
Collection (TA0009)	T1560.001	Archiviazione con utility	ntds.dit e SYSTEM compressi negli archivi SYSTEM.zip e comps.zip	30
Collection (TA0009)	T1113	Cattura dello schermo	scr.exe, lanciato con attività pianificate e PsExec, per fare screenshot dei sistemi e di una interfaccia operatore (HMI)	27, 30-31
Command and Control (TA0011)	T1105	Trasferimento di strumenti in ingresso	Scaricati strumenti da un server remoto	32

Nota sulle versioni: i codici sono quelli del report;

4. Havex e TRITON in sintesi

Havex (2013-2014) e TRITON (2017) sono descritti con tecniche ATT&CK for Enterprise e soprattutto ATT&CK for ICS, il framework dedicato ai sistemi di controllo industriale.

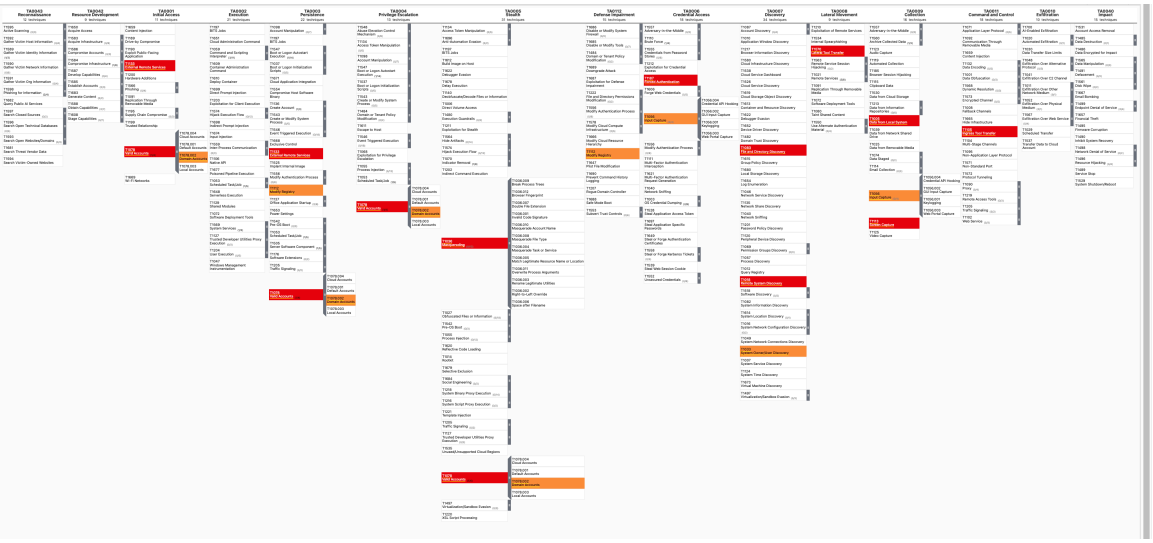
Episodio	Tattica	ID	Tecnica	Cosa faceva	Pag.

Episodio	Tattica	ID	Tecnica	Cosa faceva	Pag.
Havex	Initial Access (ICS)	T0865	Allegato di spearphishing	Installer trasformato in trojan allegato a email	12
Havex	Initial Access (ICS)	T0862	Compromissione della catena di fornitura	Installer manomessi caricati su siti compromessi di fornitori	12
Havex	Persistence (Enterprise)	T1547.001	Chiavi Run del registro	Persistenza al riavvio tramite le chiavi di avvio automatico	8
Havex	Defense Evasion (Enterprise)	T1070.004	Cancellazione di file	Modulo di pulizia che rimuove le tracce dalla rete	9
Havex	Discovery (ICS)	T0846, T0888	Scoperta di sistemi remoti e delle loro informazioni	Individua i server OPC raggiungibili e ne raccoglie i dati	12-13
Havex	Collection (ICS)	T0802, T0861	Raccolta automatica e identificazione di punti e tag	Elenca i tag OPC (nome, tipo, accesso, ID)	13
Havex	Impact (ICS)	T0813	Negazione del controllo	Può impedire ai PLC di controllare i sistemi collegati	13
TRITON	Initial Access (ICS)	T0818	Compromissione di una workstation di ingegneria	Compromette postazioni nella rete di sicurezza	33
TRITON	Execution (ICS)	T0858	Cambio della modalità operativa	Ferma o avvia programmi tramite il protocollo TriStation	33
TRITON	Persistence (ICS)	T0857	Firmware di sistema	Inietta il codice nel firmware in esecuzione dei PLC Triconex	34
TRITON	Command and Control (ICS)	T0885	Porta di uso comune	Comunicazione con i PLC tramite UDP 1502	34
TRITON	Impact (ICS)	T0880	Perdita di sicurezza	Può riprogrammare la logica del PLC di sicurezza lasciando persistere condizioni	35

Episodio	Tattica	ID	Tecnica	Cosa faceva	Pag.
				pericolose	

5. Mappa ATT&CK Navigator

La mappa mostra le 23 tecniche principali (in rosso) e le 12 collegate (in arancione) della campagna 2016-2018 sulla matrice ATT&CK Enterprise. I codici sono quelli del report (ATT&CK v10), mentre la matrice è mostrata nella versione attuale di Navigator (v20), dove alcune tattiche hanno nomi diversi: la tattica che il report chiama Defense Evasion compare come Stealth.



Matrice ATT&CK Enterprise (Navigator, v20): rosso = tecnica principale del report, arancione = tecnica collegata.

6. Valutazione e implicazioni per una realtà energetica come Eni

Alla luce dell'analisi della campagna descritta nel report CISA AA22-083A, le tre tecniche che un'infrastruttura critica dovrebbe prioritariamente presidiare e monitorare sono:

1. T1078 / T1133 (Account validi e servizi remoti esterni)
   Perché per Eni: Rappresentano la principale porta d'accesso iniziale sfruttata dagli attaccanti (VPN e accessi esterni sprovvisti di MFA).
   Regola di rilevamento (Esempio): Generare un alert di sicurezza se un account utente effettua un accesso tramite VPN o portale remoto da una geolocalizzazione insolita, fuori dall'orario lavorativo abituale o in assenza di un completamento corretto della verifica MFA.
2. T1003.003 (Estrazione del database Active Directory - ntds.dit)
   Perché per Eni: Evidenzia che l'attaccante ha già ottenuto privilegi elevati sul Domain Controller; intercettare questo tentativo blocca la compromissione totale del dominio aziendale.
   Regola di rilevamento (Esempio): Monitorare e bloccare in tempo reale qualsiasi tentativo di accesso anomalo, lettura a basso livello o copia non autorizzata del file `ntds.dit` o dei registri di sistema da parte di processi non censiti.

3. T1570 (Movimento laterale di strumenti - PsExec, RDP, condivisioni SMB)
   Perché per Eni: È il passaggio critico in cui l'attaccante si sposta dall'area IT aziendale verso la rete di controllo industriale (OT), rendendo fondamentale la segmentazione delle reti.
   Regola di rilevamento (Esempio): Attivare sonde di rete e IDS interni per rilevare l'esecuzione anomala di comandi di amministrazione remota (come PsExec o traffico su porte SMB/RDP) tra subnet non autorizzate o verso i sistemi di controllo degli impianti.

- Considerazione sui fornitori (Supply Chain Security): Dal report emerge chiaramente che l'attacco iniziale è spesso passato attraverso la compromissione di partner e fornitori terzi. Per un'azienda come Eni, la sicurezza non deve limitarsi al perimetro interno, ma estendersi alla verifica rigorosa della postura di sicurezza e dei controlli d'accesso adottati dalla filiera dei fornitori.